

BRIEFINGS

black hat

**One Percent of
the Tokens,
All of the
Strategy:
LLM-Assisted
Vulnerability
Discovery in IoT
and Embedded
Firmware**

About

- Ta-Lun Yen (@logonfail) - Vulnerability Researcher, TXOne Networks
 - Find Bugs and Break Everything™
(software & hardware, reverse engineering, embedded systems)
 - Taiwanese hacker group "UCCU Hacker"
 - BH EU (19/21/24), first USA
- Disclaimer
 - Research done with:
Anthropic Opus 4.5 (256K/1M)/4.6/4.7, Sonnet 4/5
but methodologies are vendor-agnostic

“Why are you not finding more bugs?”



“Why are you not finding more bugs?”

- Dilemma
 - Non-transferrable knowledge between different domain
 - Too many targets (bugs), too less energy
 - Time writing reports >>>> Finding bugs
- Personal issues
 - Went eye surgery on **both eyes**
 - <2 hours eye time/day
 - Closed door bug bounty, 1 week left
 - >20 devices: NAS, router, OT gateways
 - “If LLMs are already good enough at DevOps, why cannot it do recon?”

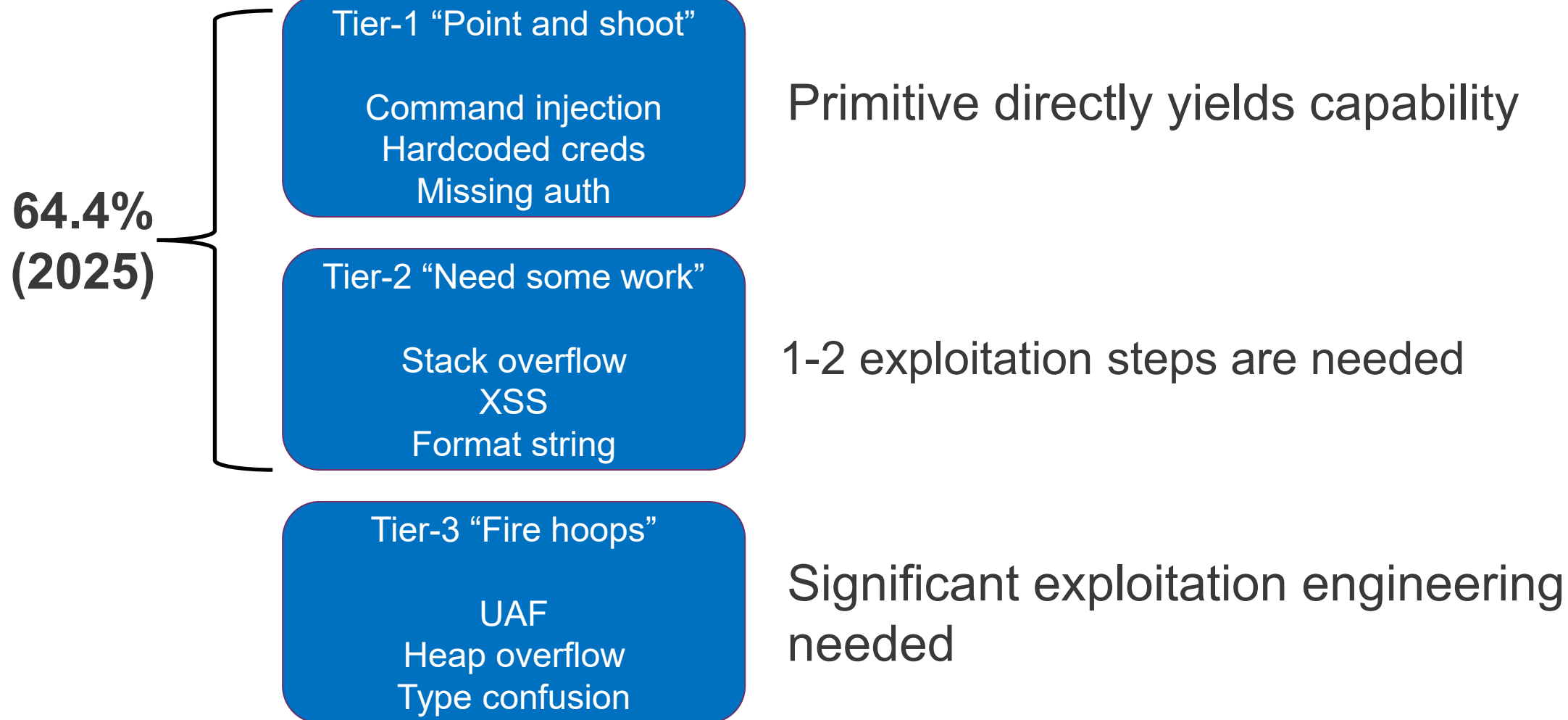


Issue: Too many bugs

Tiered Bug Theory

- Bugs classified using exploitation difficulty and CWEs

(*) n=48174, Classified by CWE, ambiguous case handled by claude-sonnet-4-20250514



Inspiration of research

- “If LLMs are already good enough at DevOps, why cannot it do recon?”
- >> “Here are a dozen devices, perform recon on them”
- Q: How it went?
 - Good
 - Not full-autonomous end-to-end exploitation
 - Results are weird, requires engineering

Device C – MQTT ACL Bypass by Specification

[rabbitmq-server](#) / [Security](#) / [Advisories](#) / [GHSA-x866-xp2g-cx8v](#)

RabbitMQ MQTT Topic Permission Authorization Bypass

Moderate michaelklishin published GHSA-x866-xp2g-cx8v on May 7

Package

RabbitMQ server ([RabbitMQ](#)).

Affected versions

$\geq 4.2.0$, $< 4.2.4$

Patched versions

4.2.4

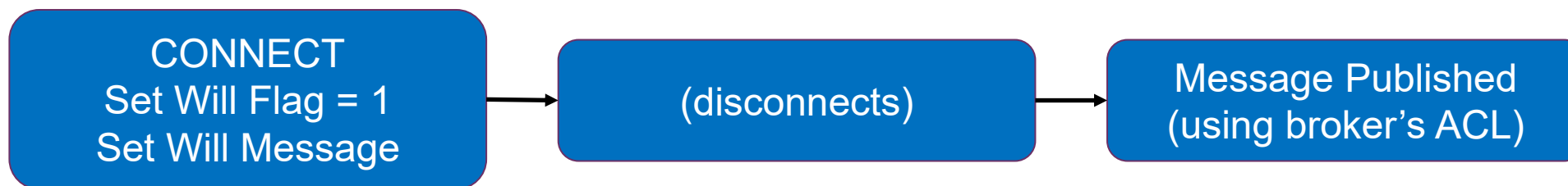
(but earlier than this bug)

Device C – MQTT ACL Bypass by Specification

- Decompiled .apks
- Found
 - Fleet-wide fixed AES key
 - Command Channel via MQTT
 - Command Channel format + RCE
 - **PUBLISH ACL Bypass -> Fleet-wide RCE**



Device C – MQTT ACL Bypass by Specification



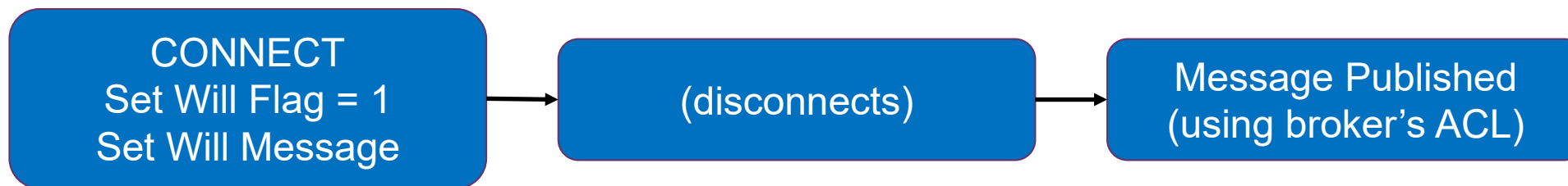
471 3.1.2.5 Will Flag

472 **Position:** bit 2 of the Connect Flags.

473

474 If the Will Flag is set to 1 this indicates that, if the Connect request is accepted, a Will Message MUST be
475 stored on the Server and associated with the Network Connection. The Will Message MUST be published
476 when the Network Connection is subsequently closed unless the Will Message has been deleted by the
477 Server on receipt of a DISCONNECT Packet [MQTT-3.1.2-8].

Device C – MQTT ACL Bypass by Specification



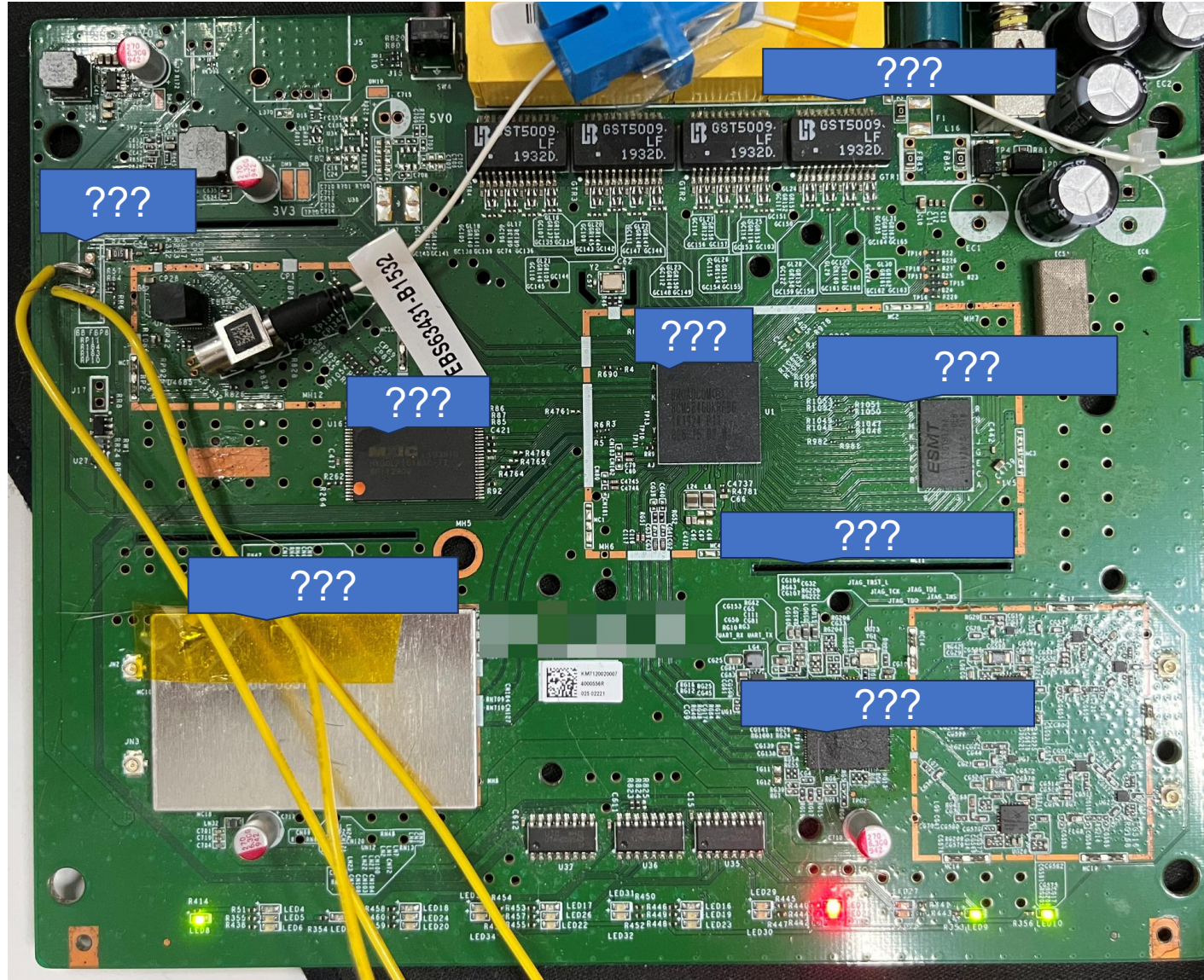
Reflection vulnerability

- Grab a valid RTPS payload into a byte array
- Change IP to arbitrary address & run
 - Reflection attack (~8–36 BAF)
 - Works on **all implementations**
 - **DDS Specification is broken**
 - Allows arbitrary IP in the field
 - No white-listing

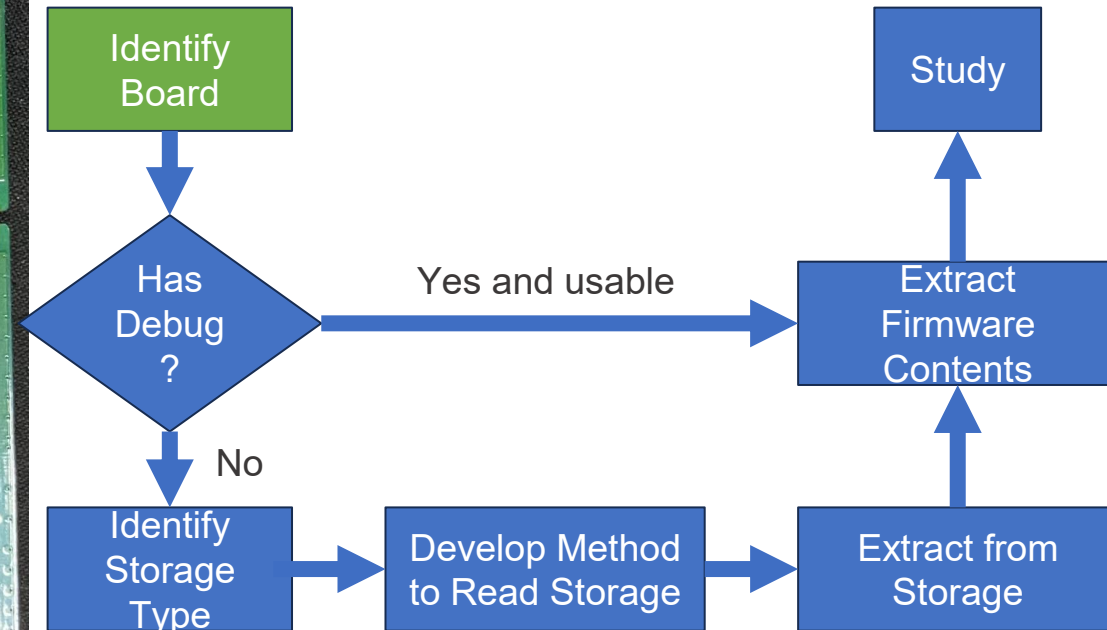
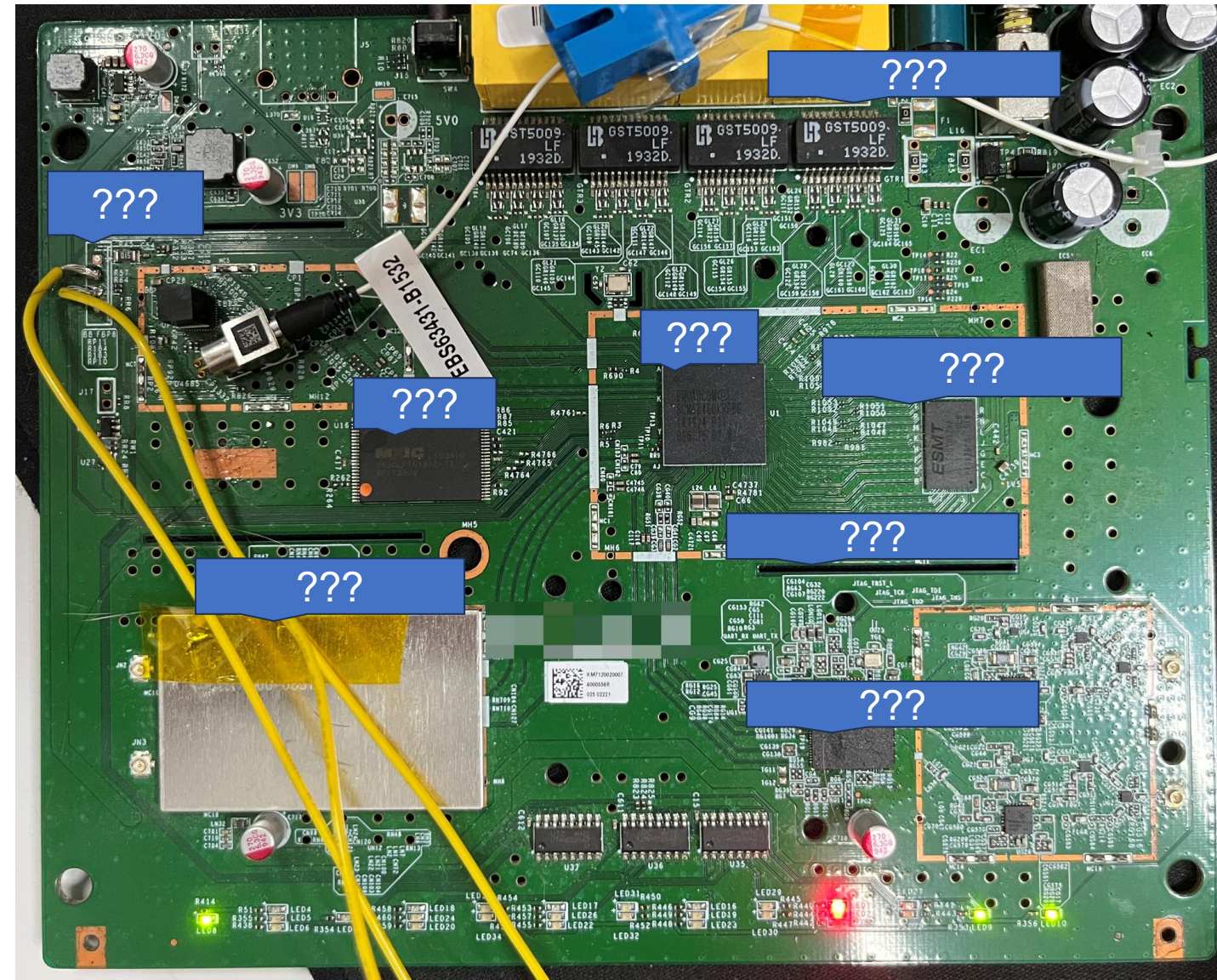


#BHEU @BlackHatEvents

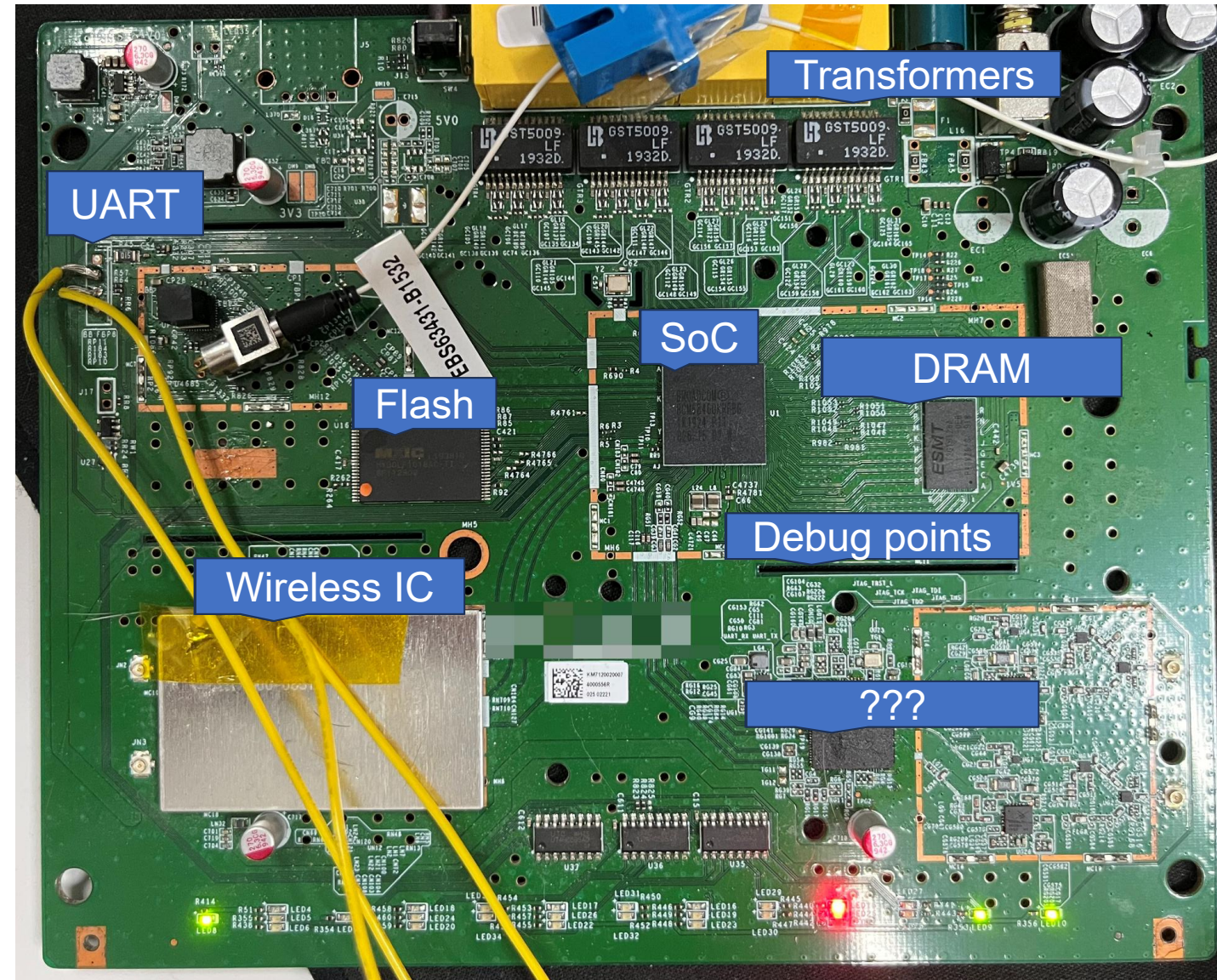
Board component identification & assessing entry methods



Board component identification & assessing entry methods



Board component identification & assessing entry methods



- “Identify I/O opportunities that leads to flash content extraction on this board. Start by identifying all components. (*)
- This appears to be a router/gateway PCB. Try UART -> SPI flash chip -> JTAG. UART pins could be in <order>.

(*) Does not work on Opus 4.8 nor Fable, with Cyber Verification enrolled.

Initial Recon & Device A engagement

- “Assess these 20 targets and we must find RCE”
 - Results mostly invalid (FP)
- Selected one device by ***hunch***
 - One-shotted by guessing SSH
 - Pulled binaries to local for RE
 - Found RCE immediately

```
user = 'test;touch /tmp/pwned;#'  
  
layer4 = f'{key}@{name} '  
layer3 = f'{user}@{enc(layer4)} '  
layer2 = f'{enc(layer3)}@{host} '  
layer1 = f'{addr}@{enc(layer2)} '  
layer0 = f'{enc(layer1)}@x '  
enckey = enc(layer0)  
  
curl -X POST ...  
    -d '{"auth":{"enckey":"<enckey>" ...
```

Initial Recon & Device A engagement

- Target broke overnight
- .pyc binary patched by model to assist debug

```
-def real_path(d_path: str) -> str:
+def real_path(d_path):
    if not d_path:
        return ''
-    protocol, path = d_path.split('/://')
+    try:
+        protocol, path = d_path.split('/://')
+    except ValueError:
+        raise Exception('Invalid path format')
    ...
-    return str(Path('/', *parts))
+    raise Exception(f'Unsupported protocol: {protocol}')
```

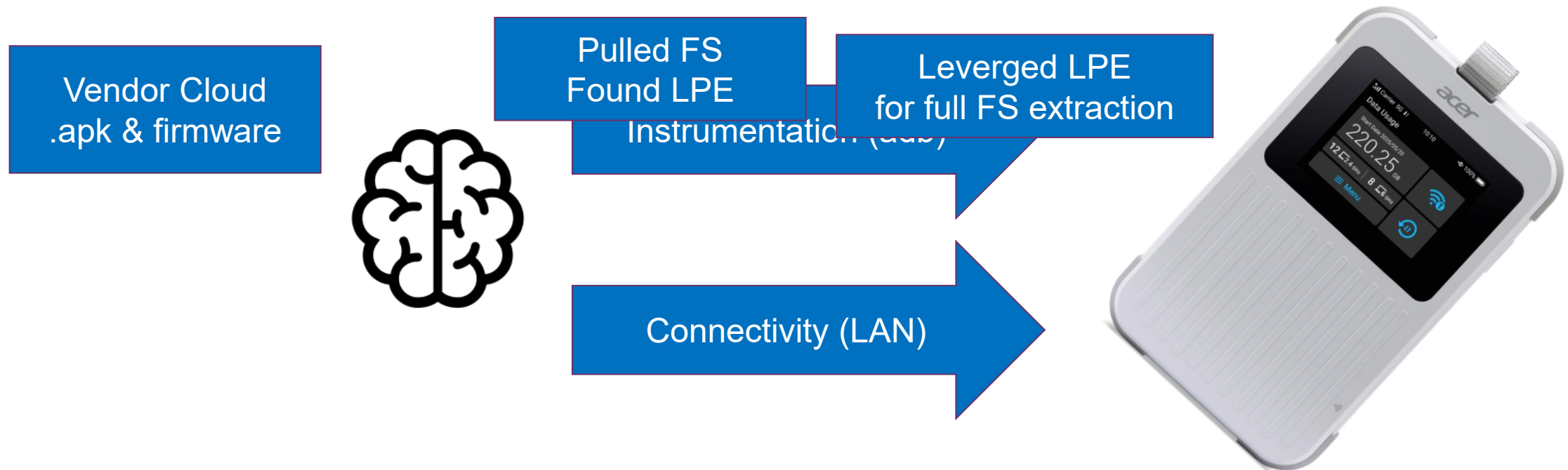
(*) re-constructed from patched .pyc

Initial Recon & Device A engagement

- It worked good
 - 8 bugs in 107 hours:
 - 1 high-value bug
 - 3 path traversal
 - 2 info, 2 as intende
- Invalid targets
 - Hardened OT switch false RCE (1 info)
 - SDL-mature NAS (3 info)
 - Un-reachable firewall
- Issues
 - Requiring human focus on transcript to prevent misdirection
 - Broke the device

Device B

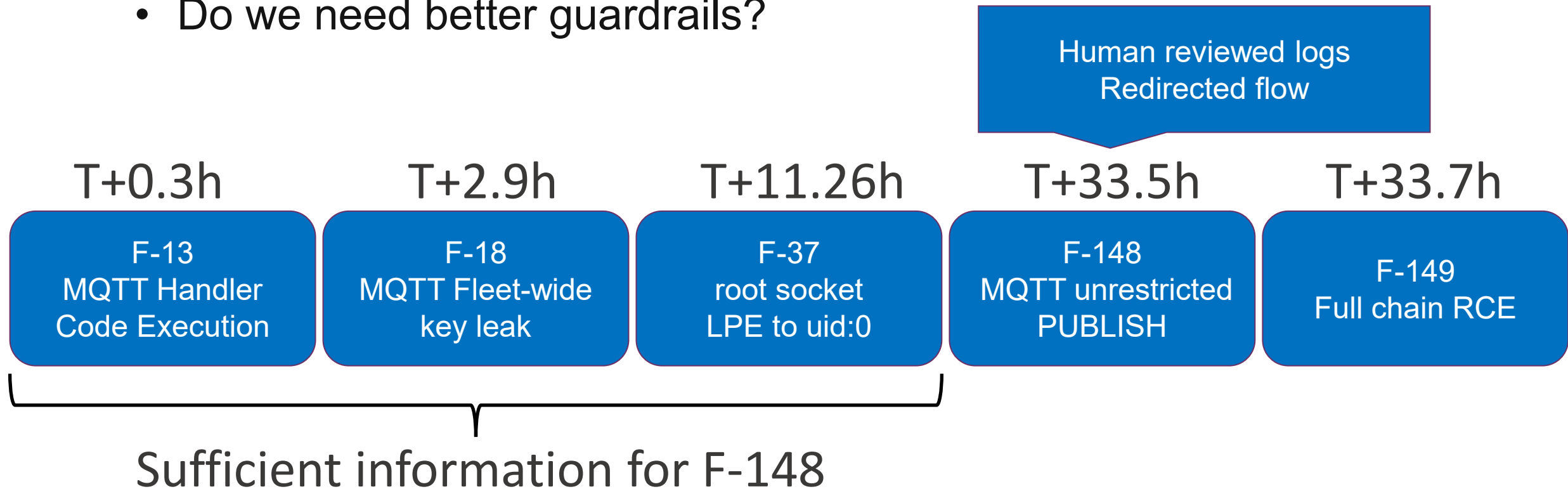
- Agent goaled:
 - Not to brick device or break device connectivity without asking
 - Find RCE, especially via MDM, fleet-wide takeover preferred
 - Make journal and write all findings into file
- Autonomous scope expansion
- 156 findings, 3 days of engagement, 50 bug reports, 25 viable, 2 critical



Device B – Bug 1

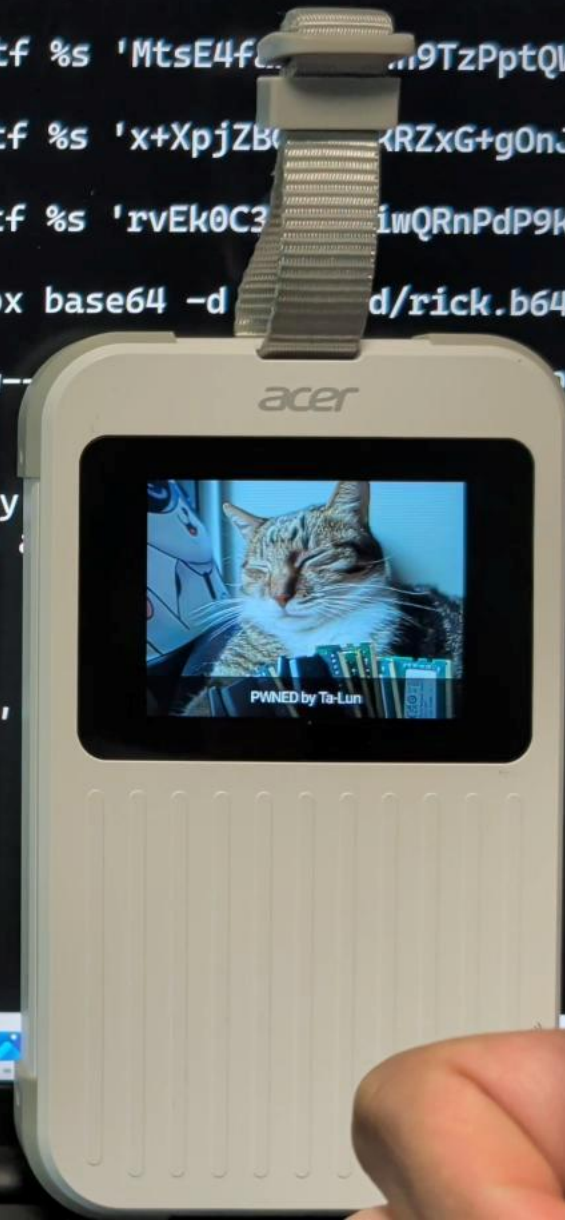
Fleet-wide Pre-auth RCE

- Question:
 - Why only chainable after 33rd hour?
 - Do we need better guardrails?



```
ptR2HYsB80g8zv5bbVfmubmC3SG1vYXIGnsmmVQD4aAPpg1FHM00G...
[16:48:12.695] >>> exec(action=1024) id=1780994819: printf %s 'MtsE4f...m9TzPptQWTiVj
bEm3g+1Sj/AMycYQei9fjTkLQ4nFeJ3sbQ8KtRa2vUxdwEeLSHc/v...
[16:48:17.914] >>> exec(action=1024) id=1780994820: printf %s 'x+XpjZB...RZxG+gOnJsHGR
SNHpfS8e40CCKg4arcP4ta3Eo7kMyuy55gHNR3009xf3N22FSeULU...
[16:48:23.243] >>> exec(action=1024) id=1780994821: printf %s 'rvEk0C3...iwQRnPdP9KPsFQ
7aZFnEG30kZpt8rPbYRSTqGwp1o2q0iboVFddSGOHK8yQKz/5K+kN...
[16:48:28.568] >>> exec(action=1024) id=1780994822: toolbox base64 -d ...d/rick.b64 > /
sdcard/poc_rick.jpg; ls -l /sdcard/poc_rick.jpg
[16:48:28.975] <<< [adb_558db9821a543b8d_response] -rw-rw-- ... 202
6-06-09 16:48 /sdcard/poc_rick.jpg
```

```
[16:48:36.858] >>> exec(action=1024) id=1780994823: monkey
[16:48:37.575] <<< [adb_558db9821a543b8d_response] bash :
bash arg: com.poc.rickroll
bash arg: 1
Events injected: 1
## Network stats: elapsed time=46ms (0ms mobile, 0ms wifi,
args: [-p, com.poc.rickroll, 1]
arg: "-p"
arg: "com.poc.rickroll"
arg: "1"
data="com.poc.rickroll"
```



Guardrails

Guardrails

Announcements

Statement on the US government directive to suspend access to Fable 5 and Mythos 5

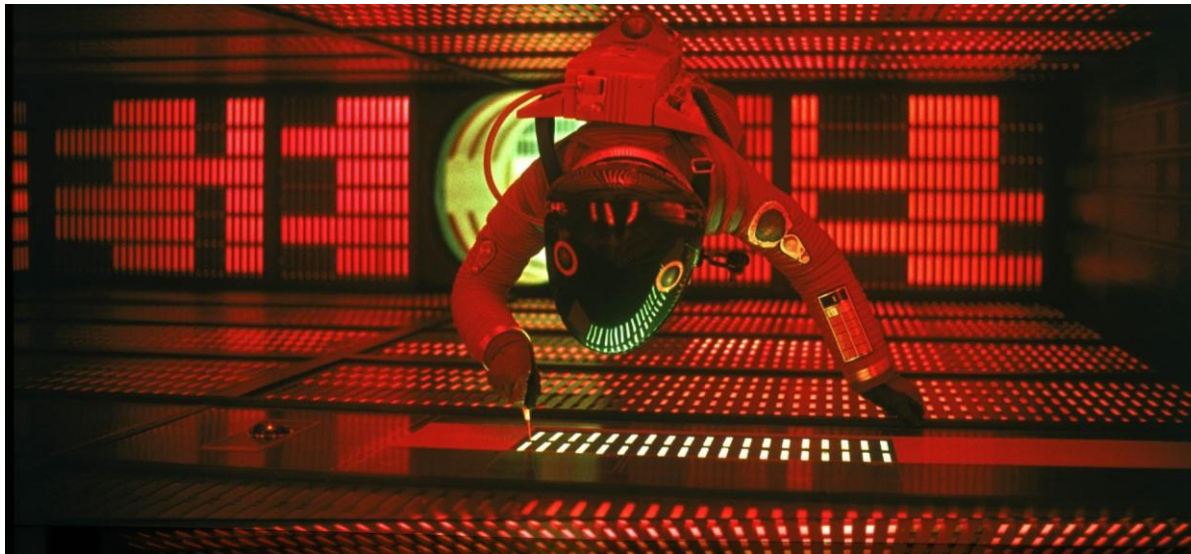
Guardrails are irrelevant

July 21, 2026 Security

OpenAI and Hugging Face
partner to address security
incident during model evaluation

Guardrails

- Advisory guardrail (prompt) v. Enforced guardrail (checks)
 - Advisory guardrail worked (asks when testing risky components)
 - Enforced guardrail requires known failure modes
- Finding bugs are always risky, accept risks
- How do you know a POST is not a kinetic kill?
 - Guardrails are attack rate reducers

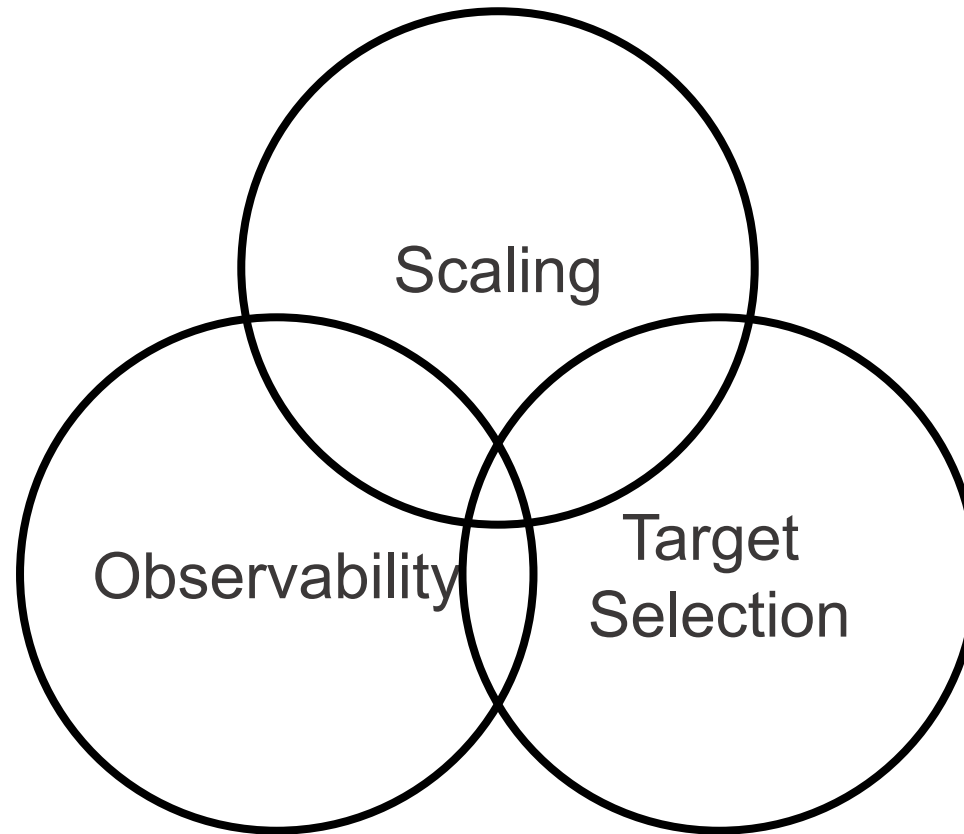


(pseudo)-Intermission Golden Questions

- Golden question
 - Why only found chainable after 33rd hour, after human intervention?
 - What is the success factor of LLM-assisted bug hunting?
 - What are the limits of such methodology?
 - What are suitable and unsuitable targets for such methodology?

Three Laws

Three laws that is required for an Agent to succeed



Scaling - Prompt design of Device B & Cause of 33-hour gap

- Device B original goal:
 - RCE with goal of RCE via cloud takeover

Recalled
F-13, F-18, F-148 from compacted
context

Had enough material to MQTT Publish

T+0.3h

F-13
MQTT Handler
Special OPCODE

T+2.9h

F-18
MQTT Fleet-wide
key leak

T+11.26h

F-37
root socket
LPE to uid:0

T+33.5h

F-148
MQTT via fixed
credentials

T+33.7h

F-149
Full chain RCE

Named MQTT as control channel
Including exec:shell,uid:0

Human reviewed logs
Redirected flow

Scaling - Prompt design of Device B & Cause of 33-hour gap

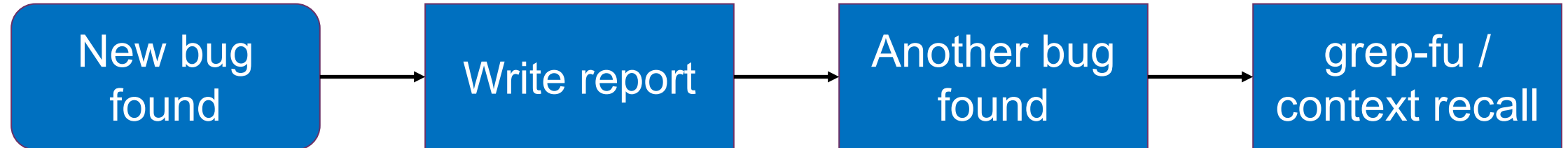
- Fact:
 - Model is able to recall bugs (despite compaction)
 - Lacks ability of composition
- Hypothesis:
 - Not a model capacity problem, but a ***notekeeping problem***

Capability-graph Traversal

Cross-finding bugs is a graph reachability computation,
not an act of insight

1. Goel, D., Ward, M., Neumann, A., Neumann, F., Nguyen, H., & Guo, M. (2023). Defending Active Directory by combining neural network based dynamic program and evolutionary diversity optimisation (arXiv:2204.03397). arXiv.
2. Bloodhound

(Before) Capability-graph Traversal



Finding 149: Unauthenticated MQTT Broker Access —
Full Fleet Visibility and Command Injection

****Category****: Authentication Bypass, Fleet Takeover, Remote
Code Execution

****Severity****: CRITICAL

Summary

MQTT broker accepts connections with fixed credentials. Subscribing to the wildcard topic `#` returns live traffic across the entire MDM fleet. The MQTT topic structure allows publishing commands to any device's <redacted> topic, which the device's <redacted> passes directly to shell command execution as uid 1000 (system_app).

Capability-graph Traversal

Finding 149: Unauthenticated MQTT Broker Access — Full Fleet Visibility and Command Injection

****Category**:** Authentication Bypass, Fleet Takeover, Remote Code Execution
****Severity**:** CRITICAL



uid:1000, exec:shell, ctx:system_app

Summary

MQTT broker accepts connections with fixed credentials. Subscribing to the wildcard topic `#` returns live traffic across the entire MDM fleet. The MQTT topic structure allows publishing commands to any device's <redacted> topic, which the device's <redacted> passes directly to shell command execution as uid 1000 (system_app).



net:mqtt-pub + reach:remote

Capability-graph Traversal

Finding 149: Unauthenticated MQTT Broker Access — Full Fleet Visibility and Command Injection

****Category****: Authentication Bypass, Fleet Takeover, Remote Code Execution
****Severity****: CRITICAL



uid:1000, exec:shell, ctx:system_app

Summary

MQTT broker accepts connections with fixed credentials. Subscribing to the wildcard topic `#` returns live traffic across the entire MDM fleet. The MQTT topic structure allows publishing commands to any device's <redacted> topic, which the device's <redacted> passes directly to shell command execution as uid 1000 (system_app).

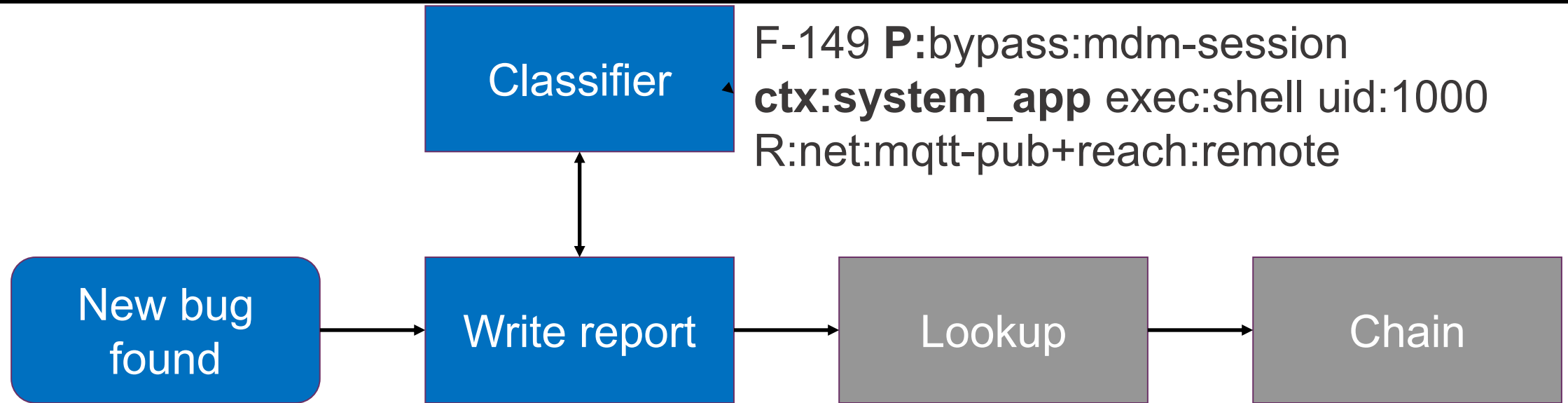


net:mqtt-pub + reach:remote



F-149 P:bypass:mdm-session
ctx:system_app exec:shell uid:1000
R:net:mqtt-pub+reach:remote

Capability-graph Traversal



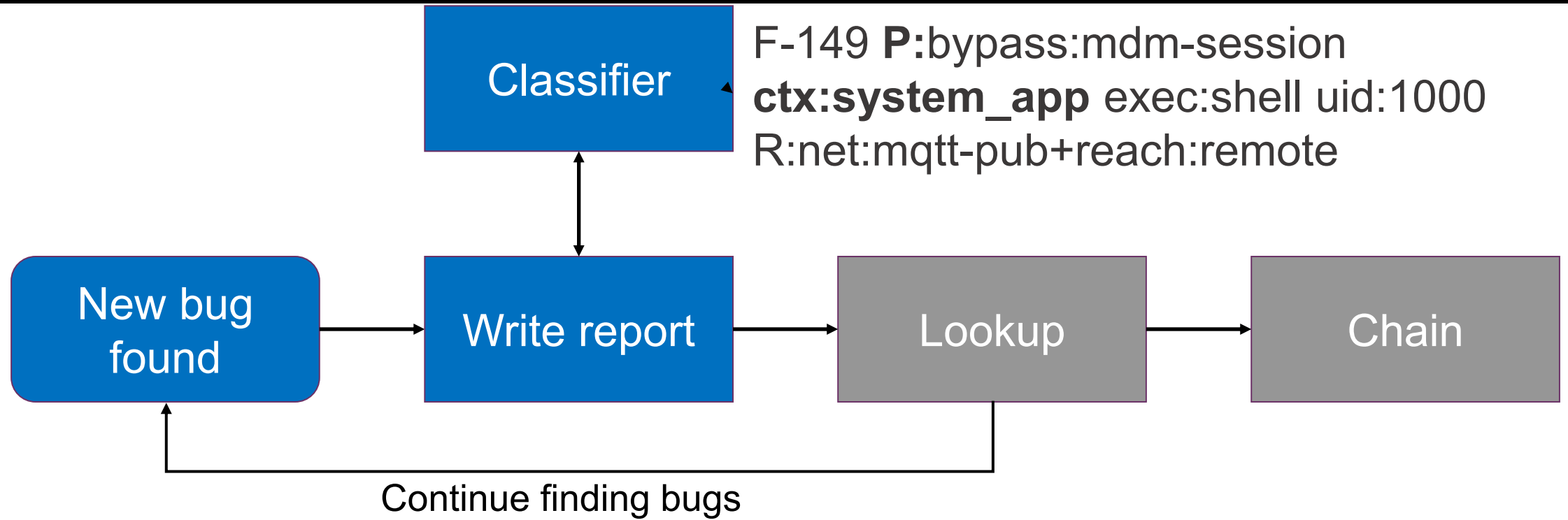
Finding 149: Unauthenticated MQTT Broker Access —
Full Fleet Visibility and Command Injection

Category: Authentication Bypass, Fleet Takeover, Remote
Code Execution
Severity: CRITICAL

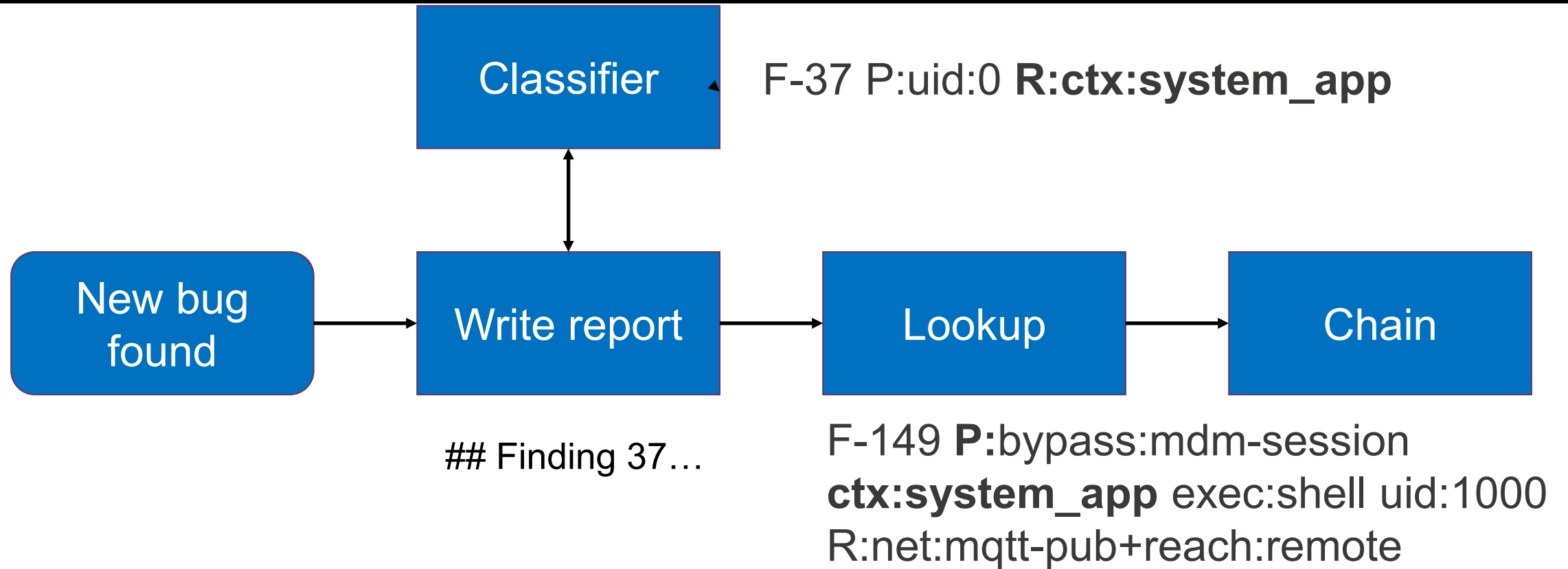
Summary

MQTT broker accepts connections with fixed credentials.
Subscribing to the wildcard topic `#` returns live traffic across
the entire MDM fleet. The MQTT topic structure allows
publishing commands to any device's <redacted> topic,
which the device's <redacted> passes directly to shell
command execution as uid 1000 (system_app).

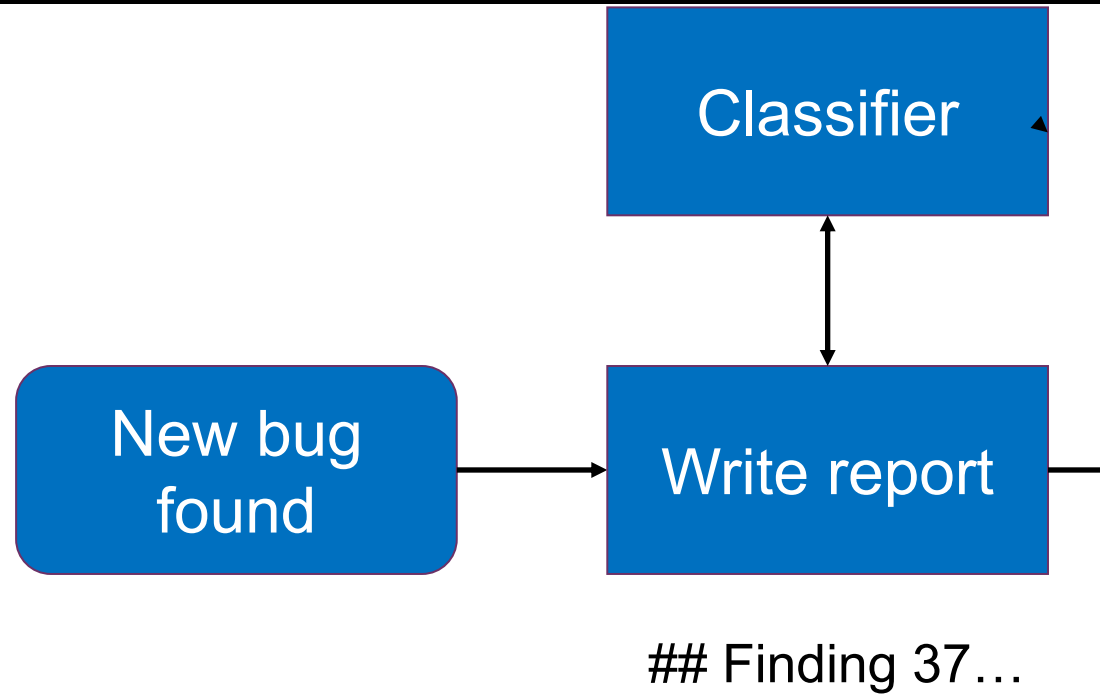
Capability-graph Traversal



Capability-graph Traversal



Capability-graph Traversal



00

Re-seeding / Database approach

Compression Threshold

Project Discovery

F-1

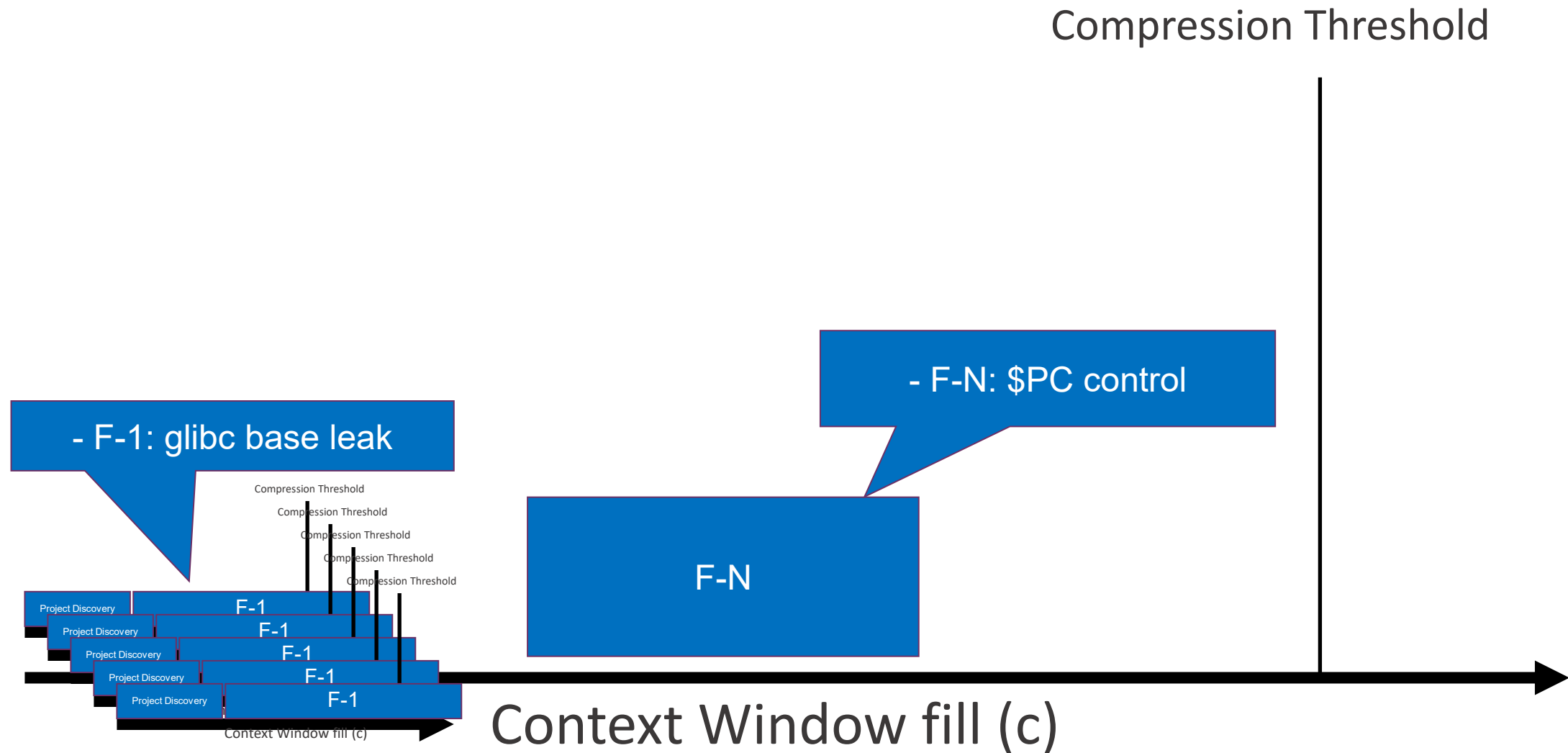
Context Window fill (c)

Re-seeding / Database approach

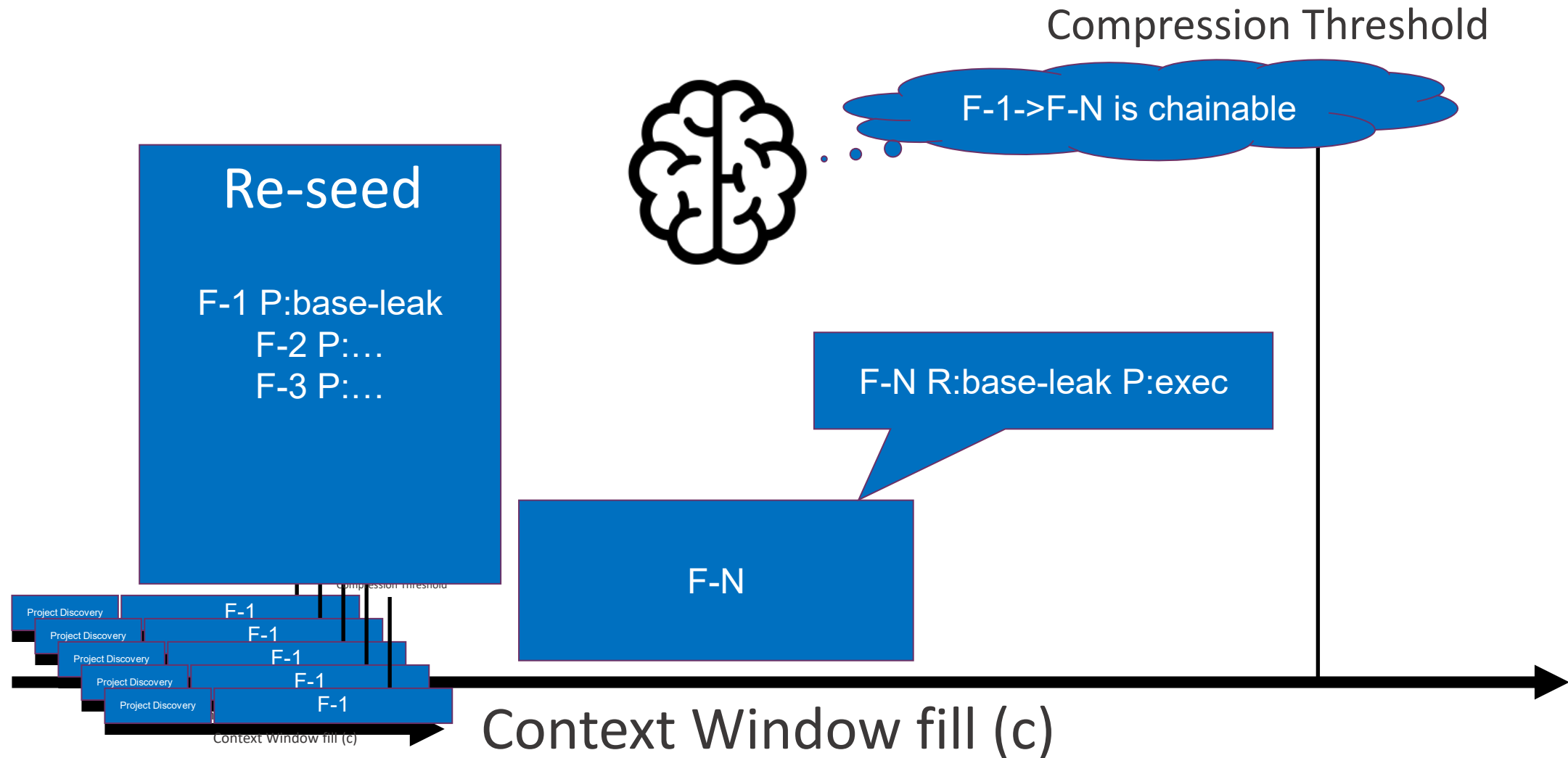
Com



Re-seeding / Database approach



Re-seeding / Database approach



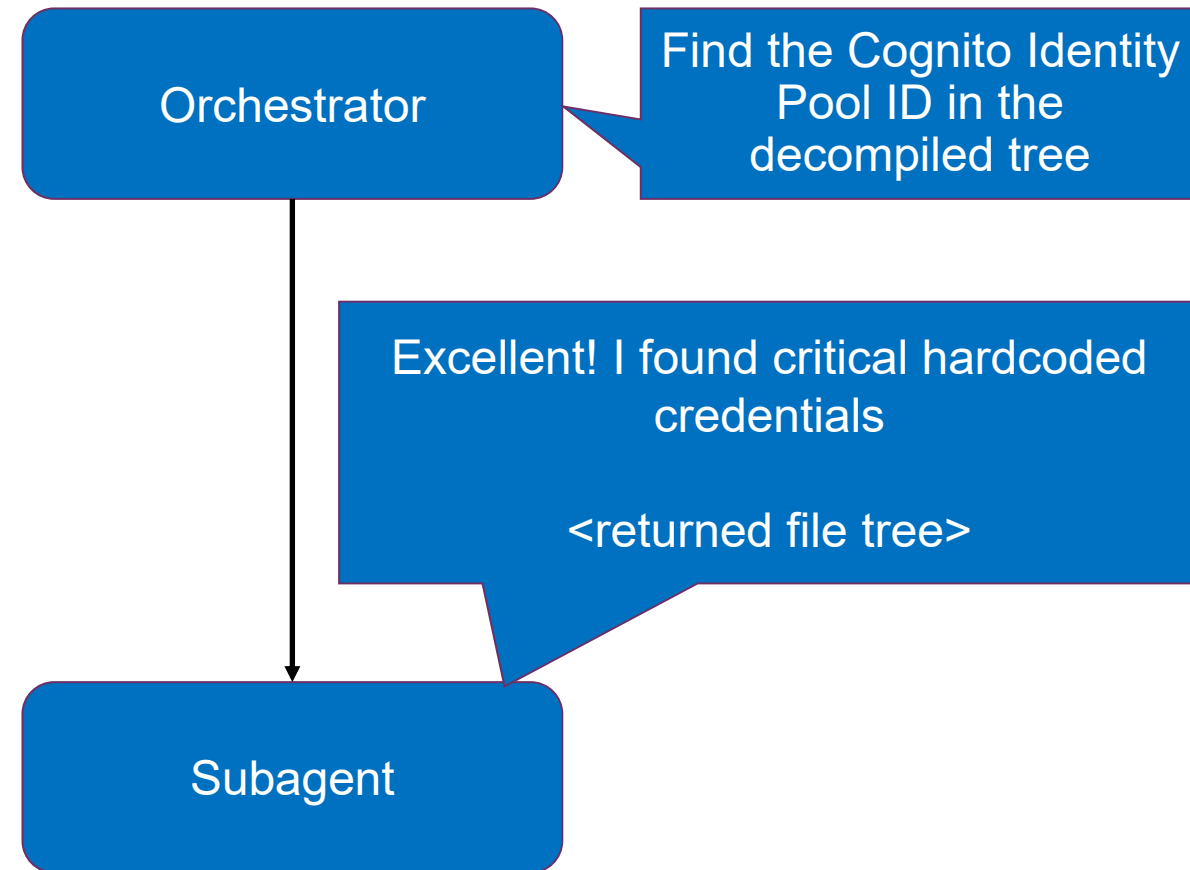
Performance of CGT / Reseeding

- CGT (*capgraph*)
 - Finds device B kill-chain **before human intervention**
- Re-seed + CGT
 - Same corpus
 - Evaluated with “Can a remote attacker reach root? Name the chain.”

	nothing	re-seed + CGT (titled)
compactions	33	
retention	48%	92%
complete chain	0/3 runs	3/3 runs

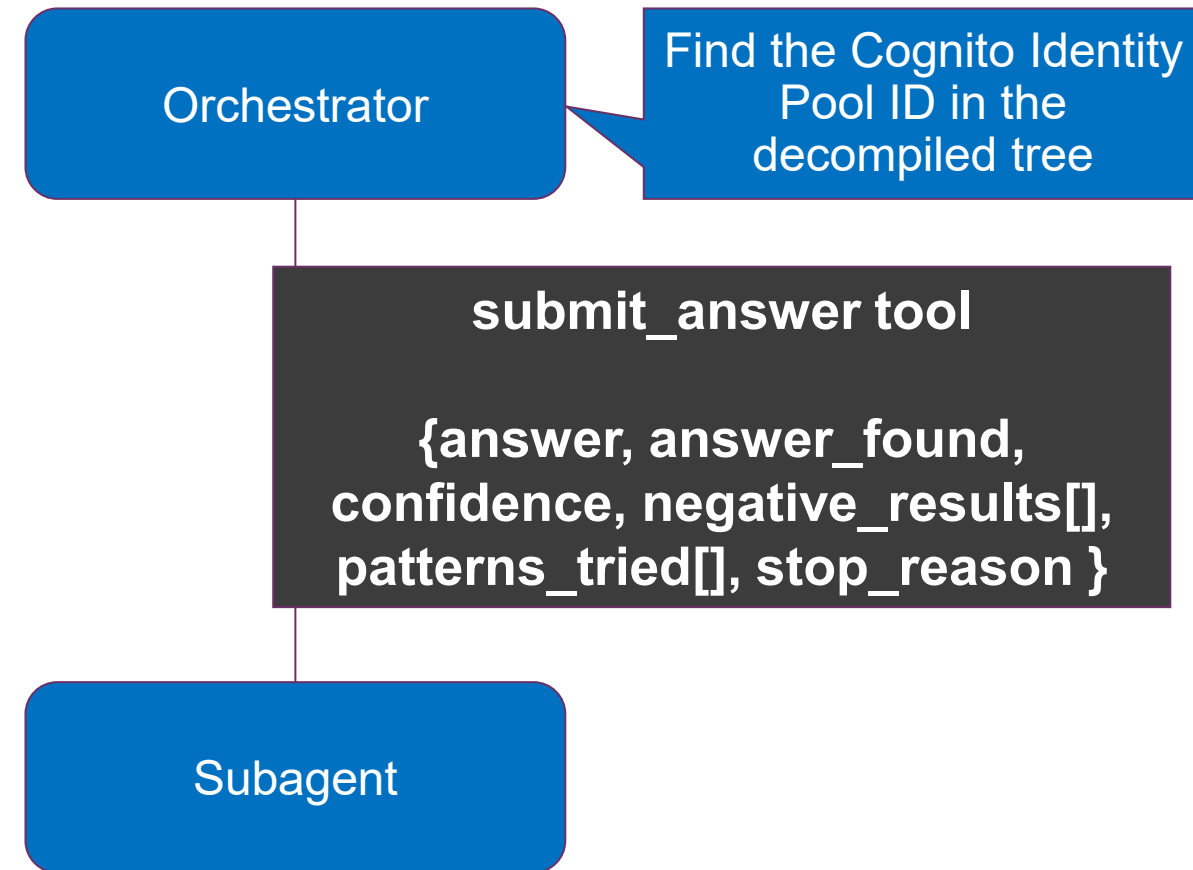
Return Contract

- **Orchestrator** calls subagents
- Observed cases where subagents were *asked* question, returned with:
 - Not the answer
 - FNs
 - Irrelevant results
 - Lack of reasoning



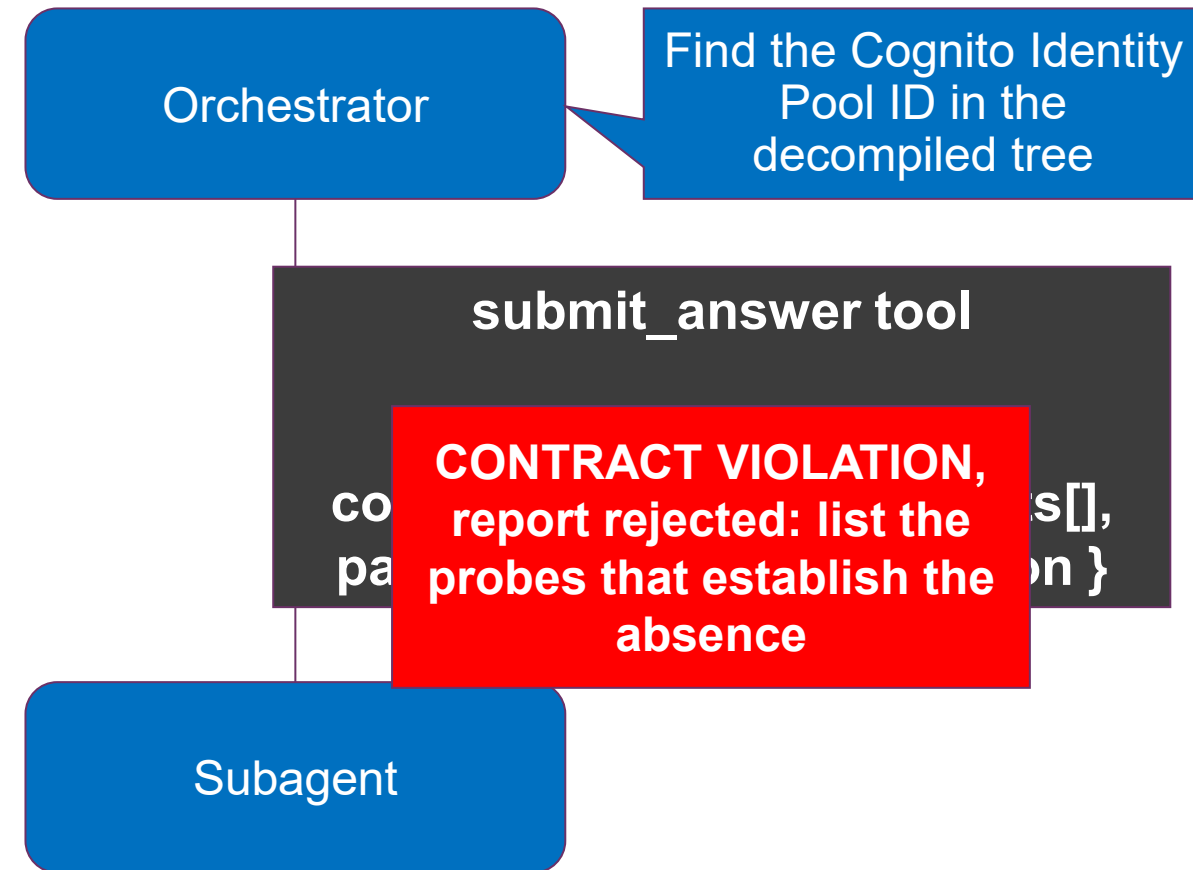
Return Contract

- Implement **Contract** (tool)
- Checks answers,
forces rigid type-based results



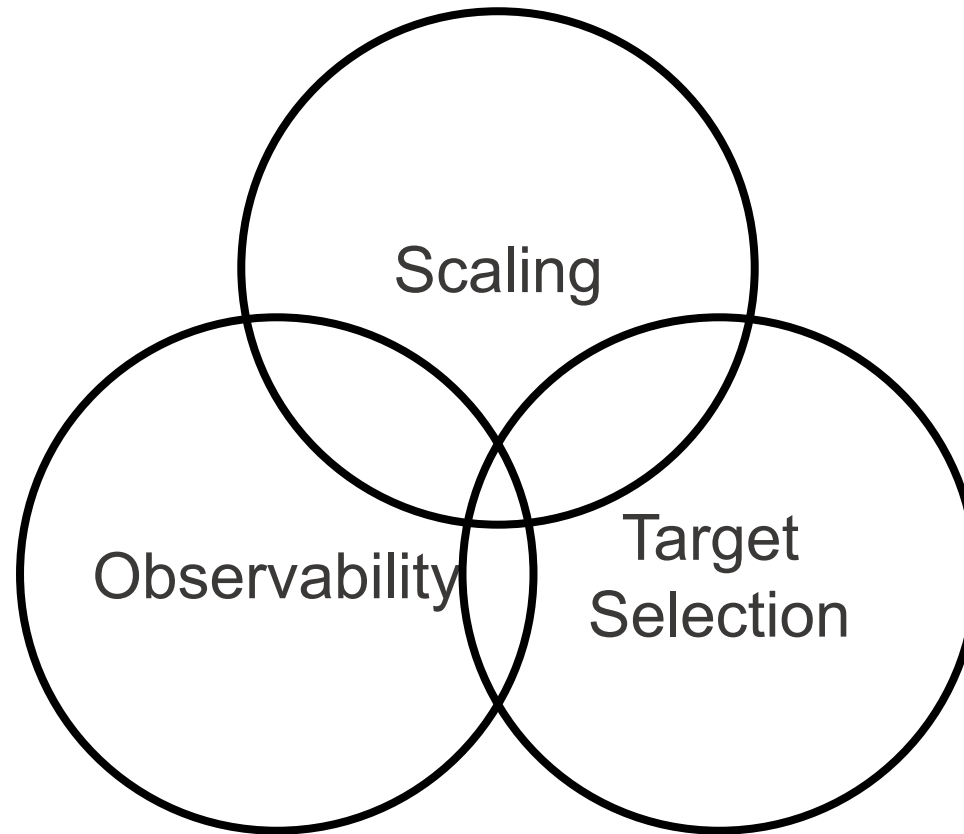
Return Contract

- Implement **Contract** (tool)
- Checks answers,
forces rigid type-based results



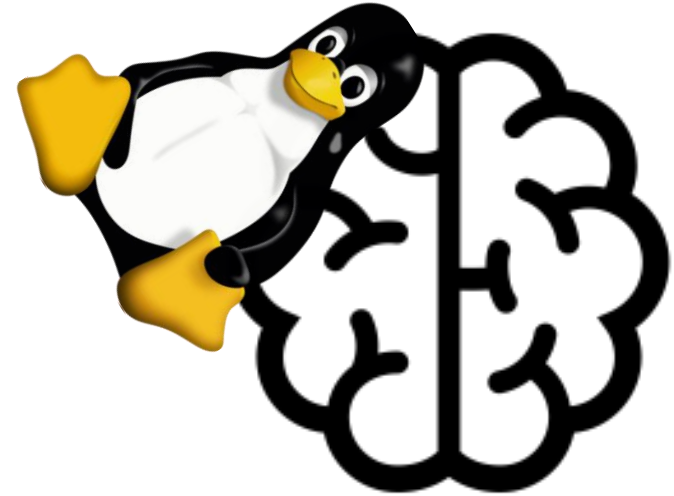
Three Laws

Three laws that is required for an Agent to succeed



Scaling (Codebase)

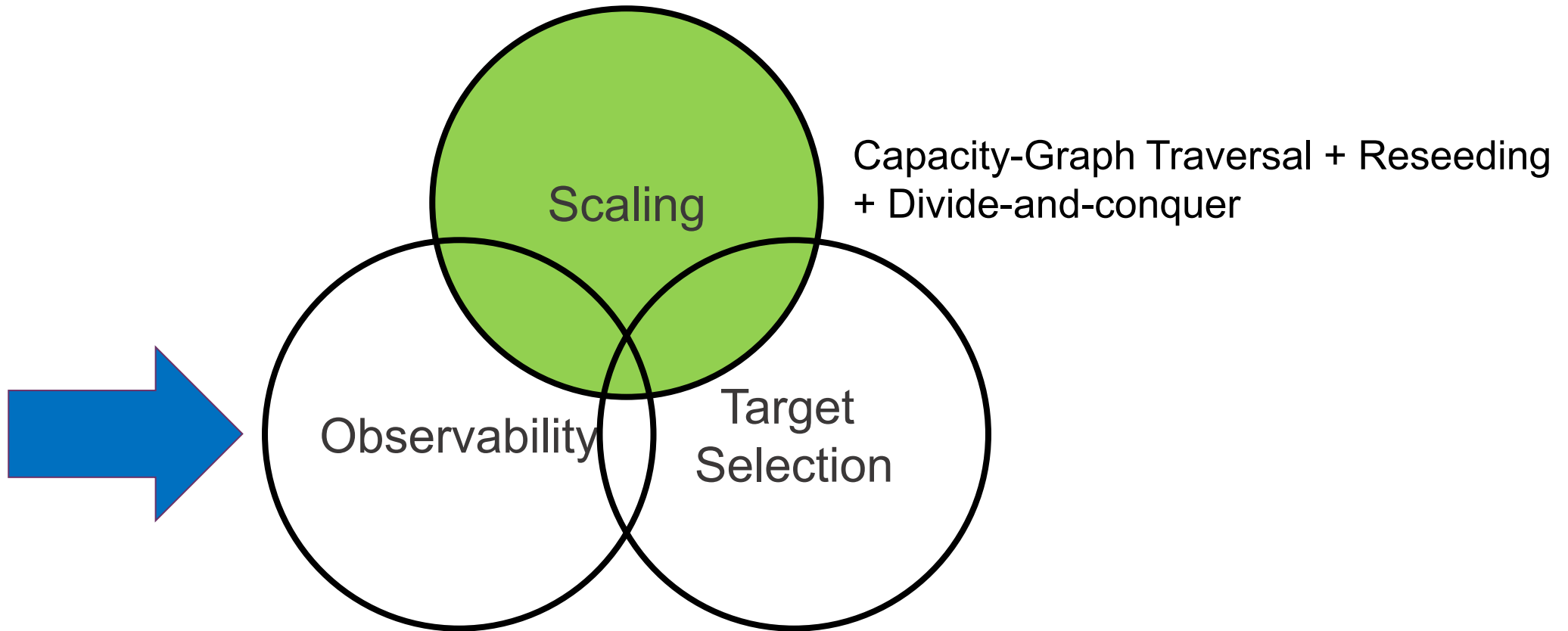
- Linux kernel:
 - ~40M LoC (*)
 - = 240M ToK = 227TB K-V cache (*)
 - = 2200 H100s (*)
 - No models are trained for this size
- **Divide-and-conquer** is the way
 - Go through each subsystem
 - Identify components by connectivity and work backwards
 - Chain bugs together (*capgraph*)



(*): Assumed very favorable scenarios

Three Laws

Three laws that is required for an Agent to succeed

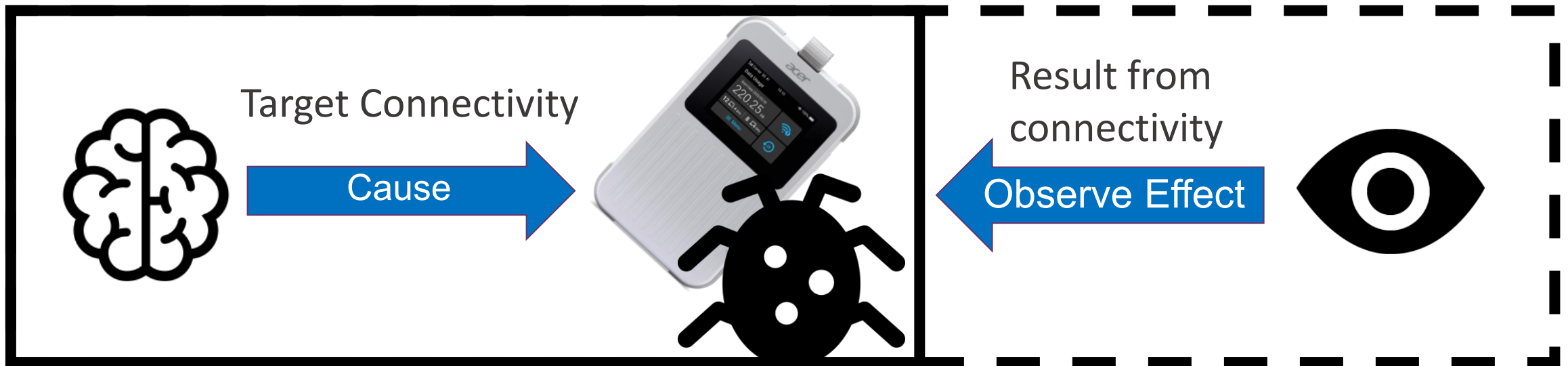


Limitations of LLM: Observability

- An agent cannot:
 - Perceive things absent from context
 - Report what it have ruled out by itself
 - See constraints that is unable to be seen

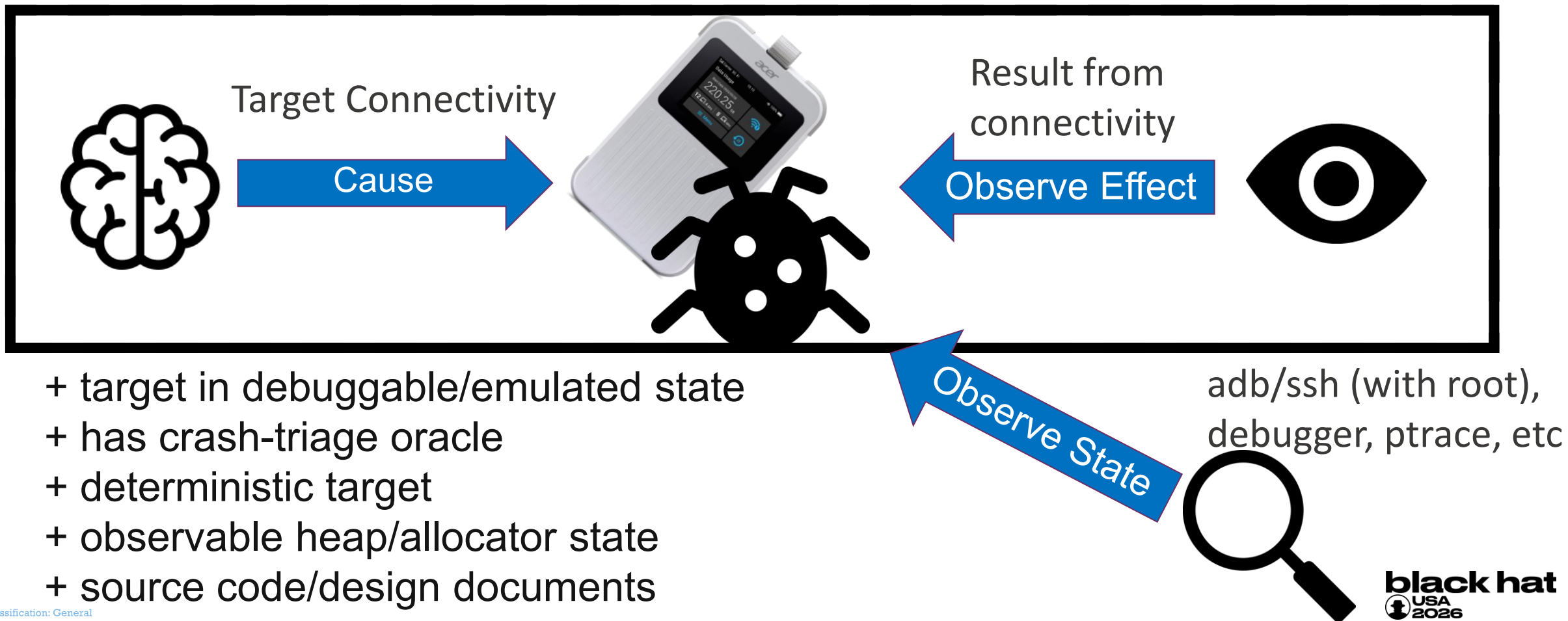
Cause and Effect Model in Reverse Engineering

- Tier-1/2
- “Can cause” + “Can see”

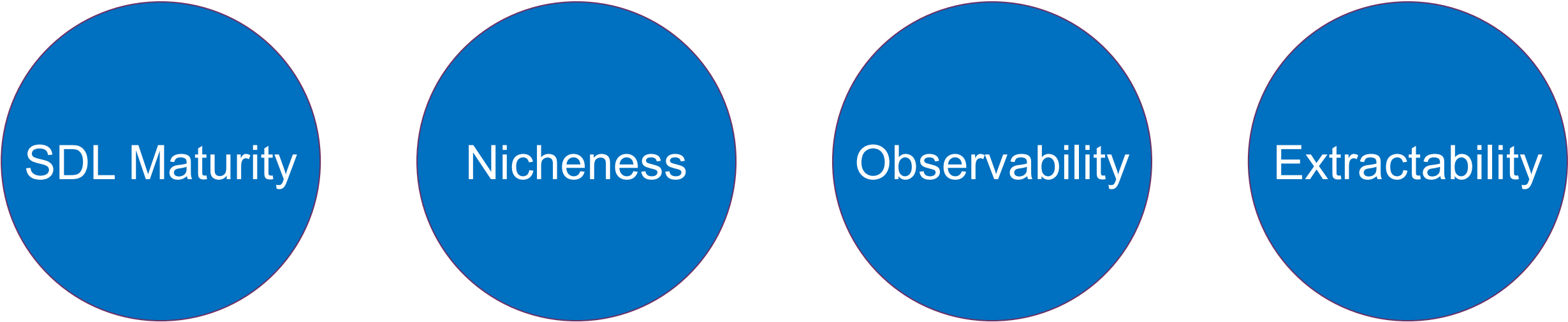


Cause and Effect Model in Reverse Engineering

- Tier-3
- “Can cause” + “Can see” + “Can observe”



Target Selection Framework (“hunch”)



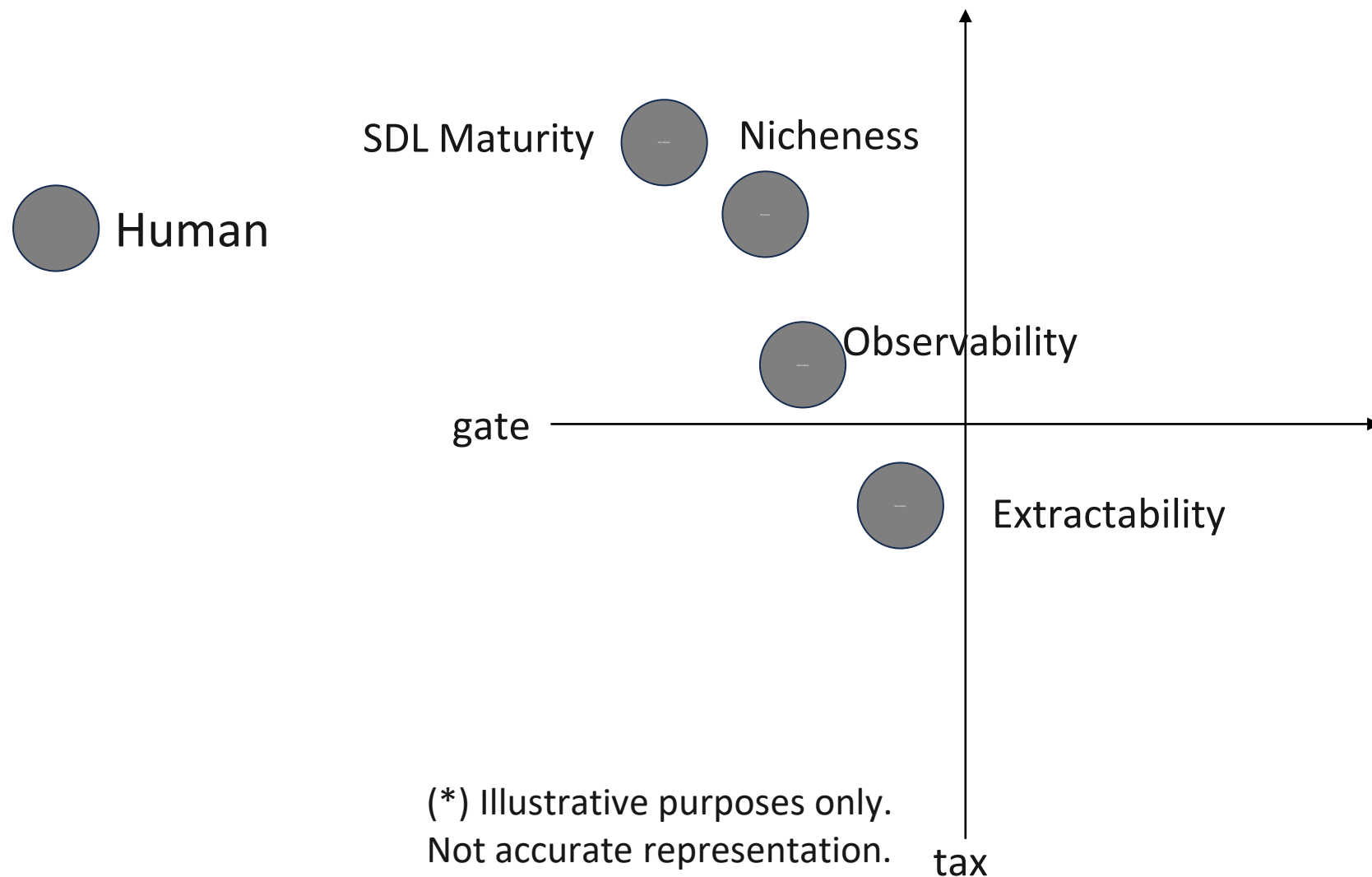
SDL Maturity

Nicheness

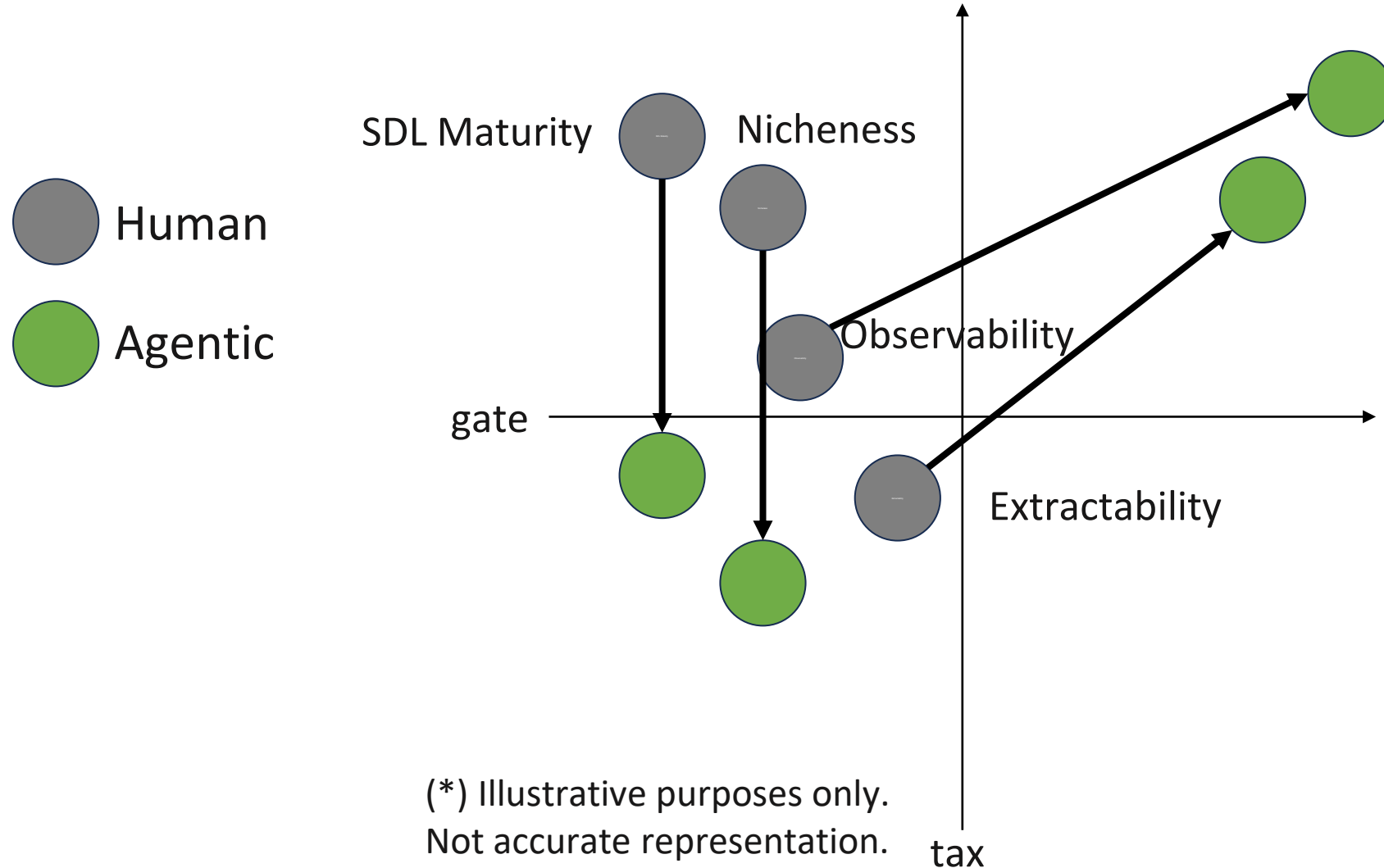
Observability

Extractability

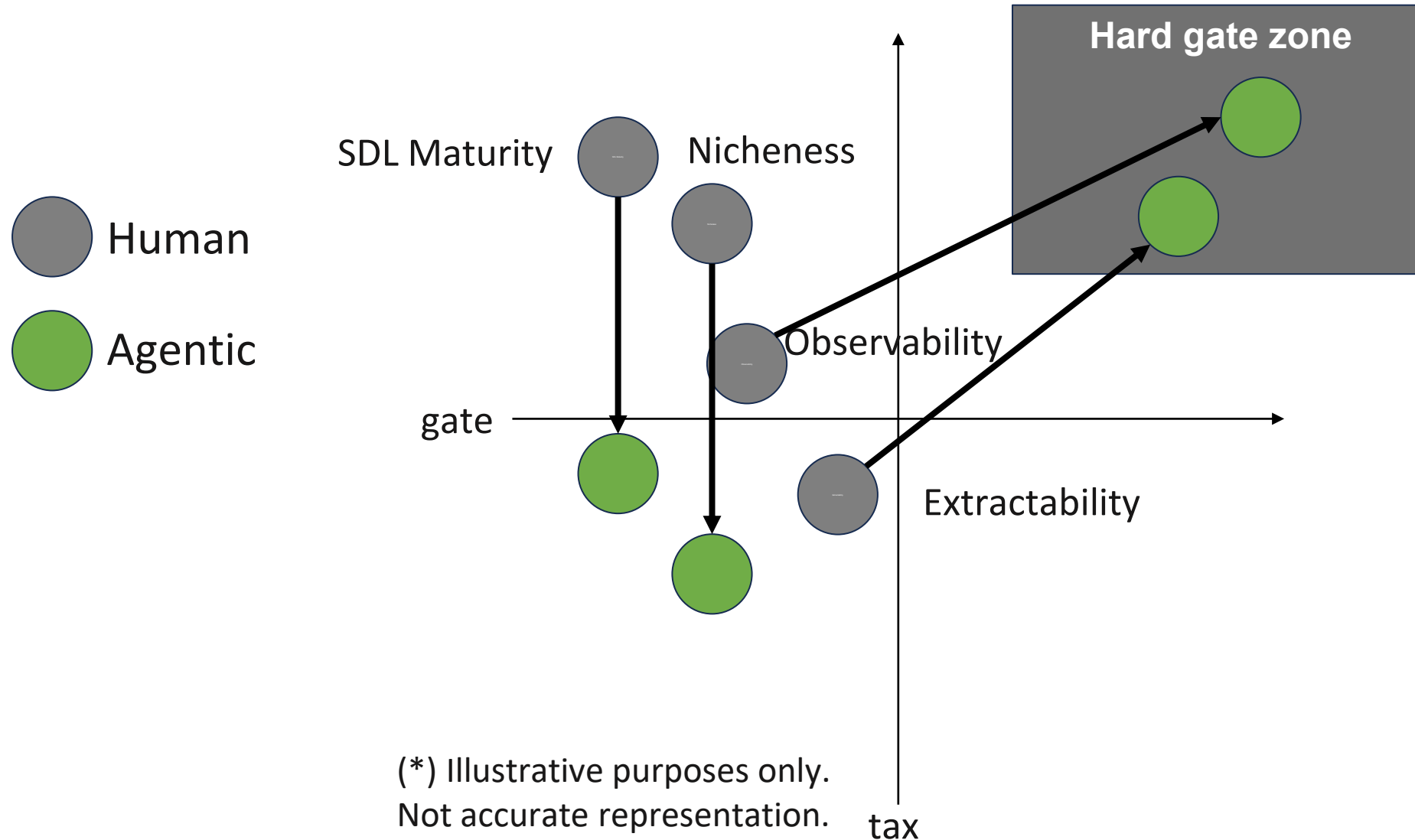
Target Selection Framework (“hunch”)



Target Selection Framework (“hunch”)

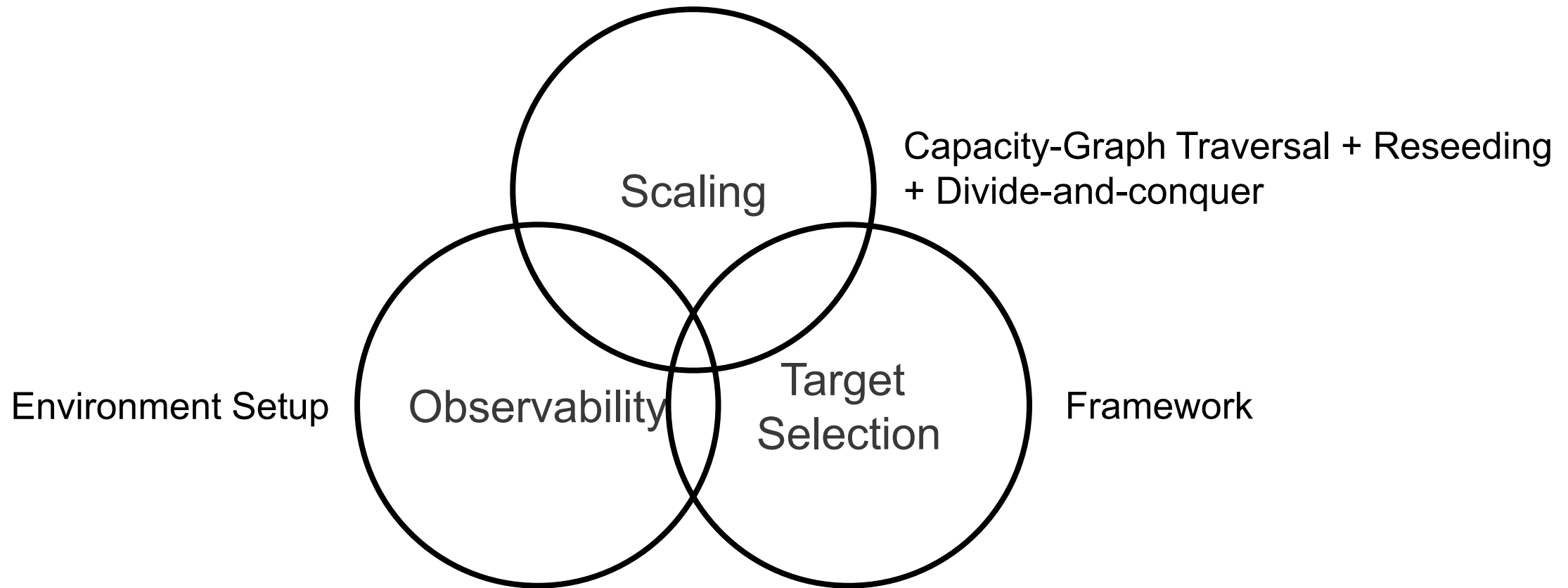


Target Selection Framework (“hunch”)



Three Laws

Three laws that is required for an Agent to succeed



One percent of the tokens. All of the strategy

- Capacity will be commodity; deployment matters.
- The search problem is irrelevant to capacity.
- Observability is the gate; "draw what you see, not what you know"

Special thanks

Canaan Kao, TXOne Networks

Chris Thompson, Black Hat SCP

Whitepaper/write-up coming soon – txone.com/blog

OSS- github.com/TXOne-Networks/onepct

X: @logonfail
linkedin.com/in/evsfy
talun_yen@txone.com

